

WORKER DIGITAL RIGHTS AUDIT

Informe de Auditoría de Derechos Digitales del Trabajador

Herramienta de auditoría técnica independiente — uso defensivo

Fecha de generación	2026-05-23 12:14:21
Riesgo máximo detectado	ROJO — Capacidad altamente invasiva
Total de hallazgos	37
Hash de sesión (integridad)	fc064df20d6fc1372bcac8f2f947d0ee...

AVISO: Este informe ha sido generado de forma automática mediante análisis de configuración local del sistema. No intercepta tráfico de red, no escala privilegios, no exfiltra datos ni compromete la infraestructura. Los hallazgos describen *capacidades técnicas detectadas*, no confirman uso indebido. Para valoración jurídica, consulte con asesor laboral especializado.

Resumen de Hallazgos

Skill	Hallazgo	Categoría	Riesgo
mdm audit	MDM / Gestión corporativa del dispositivo	Corporate Control	YELLOW
surveillance audit	CrowdStrike Falcon detectado	edr xdr	YELLOW
surveillance audit	Microsoft Defender for Endpoint detectado	edr xdr	YELLOW
surveillance audit	Certificado raíz de inspección SSL/TLS detectado	ssl inspection	ORANGE
surveillance audit	Extensiones de navegador forzadas por política corporativa	browser inspection	ORANGE
persistence audit	Servicios con características de monitorización (25 detectados)	persistence services	YELLOW
network monitor	Conexiones externas activas (19 establecidas)	network external	YELLOW
activity monitor	Procesos con alto consumo de recursos (17 detectados)	activity resources	YELLOW
activity monitor	Servicios instalados en los últimos 7 días (5)	activity new services	YELLOW
activity monitor	Procesos con múltiples conexiones salientes (2)	activity data senders	YELLOW
privacy audit	Posible acceso al portapapeles detectado (1 apps)	privacy clipboard	ORANGE
ai telemetry audit	Nivel de telemetría de Windows: Completa (por defecto, sin política re	telemetry windows level	RED
ai telemetry audit	Servicios de telemetría activos (3 en ejecución)	telemetry services	RED
ai telemetry audit	Telemetría de Microsoft Office/365	telemetry office	ORANGE
ai telemetry audit	Experiencias conectadas de Office activas — contenido enviado a Micros	ai connected experiences	ORANGE
cloud sync audit	Microsoft OneDrive activo — sincronización en segundo plano	cloud sync service	ORANGE
cloud sync audit	SharePoint / OneDrive Empresarial activo — sincronización en segundo p	cloud sync service	ORANGE
cloud sync audit	Carpetas del sistema redirigidas a nube (7 carpetas)	cloud sync folder redirect	RED
cloud sync audit	Políticas corporativas de OneDrive activas — KFM forzado por GPO	cloud sync policy	ORANGE
browser audit	Extensiones forzadas por política corporativa (1 extensiones)	browser forced extensions	ORANGE
browser audit	Políticas corporativas en Google Chrome (3 activas)	browser policies	ORANGE
browser audit	Políticas corporativas en Microsoft Edge (4 activas)	browser policies	ORANGE
browser audit	Políticas corporativas en Mozilla Firefox (1 activas)	browser policies	ORANGE
hardening audit	Configuraciones de seguridad ausentes (8 de 14)	hardening missing	RED
hardening audit	AUSENTE: BitLocker — Cifrado de disco	hardening encryption	RED

Skill	Hallazgo	Categoría	Riesgo
hardening audit	AUSENTE: Secure Boot — Arranque seguro	hardening boot	ORANGE
hardening audit	AUSENTE: Windows Firewall — Cortafuegos	hardening network	ORANGE
hardening audit	AUSENTE: Windows Defender — Protección en tiempo real	hardening antimalware	ORANGE
identity audit	Grupo Administradores: 4 miembros	identity admin group	ORANGE
identity audit	Acceso remoto habilitado	identity remote access	ORANGE
identity audit	Credenciales almacenadas en Windows Credential Manager (42)	identity stored credentials	ORANGE
identity audit	Servicios con cuentas de usuario específicas (8)	identity service accounts	YELLOW
identity audit	Procesos de monitorización con privilegios de sistema (1)	identity privileged monitoring	YELLOW
identity audit	Perfiles de cuentas — 5 con alertas (3 alto riesgo)	identity account profiles	ORANGE
identity audit	Cuenta: DevToolsUser — 2 alertas	identity suspicious account	ORANGE
identity audit	Cuenta: EMEAL-IT — 2 alertas	identity suspicious account	RED
identity audit	Cuenta: Local-Admin — 3 alertas	identity suspicious account	RED

Detalle de Hallazgos

#1 — MDM / Gestión corporativa del dispositivo

YELLOW

Skill: mdm_audit | Categoría: Corporate Control | Timestamp: 2026-05-23T12:02:28.819598

Qué es:

MDM (Mobile Device Management) es software que permite a las empresas gestionar dispositivos corporativos: aplicar políticas de seguridad, instalar apps, configurar VPN y, en caso extremo, borrar el dispositivo.

Qué NO implica:

MDM por sí solo no implica monitorización de actividad, lectura de mensajes personales ni vigilancia en tiempo real. Gestiona el dispositivo, no espía al usuario.

Riesgo técnico:

MDM permite a la organización instalar software, aplicar políticas, borrar el dispositivo remotamente y restringir aplicaciones.

Riesgo jurídico:

La gestión MDM en dispositivos corporativos es generalmente legítima bajo el ET y LOPDGDD si está informada al trabajador.

#2 — CrowdStrike Falcon detectado

YELLOW

Skill: surveillance_audit | Categoría:edr_xdr | Timestamp: 2026-05-23T12:02:28.878005

Qué es:

Agente EDR/XDR detectado. Estos sistemas monitorizan comportamiento del sistema en tiempo real para detectar amenazas.

Qué NO implica:

No implica necesariamente lectura de contenido personal. Es seguridad corporativa estándar en empresas medianas y grandes.

Riesgo técnico:

Monitoriza procesos, red y comportamiento del sistema.

Riesgo jurídico:

Riesgo legal estimado: low-medium. Ver compliance engine para análisis LOPDGDD/RGPD.

#3 — Microsoft Defender for Endpoint detectado

YELLOW

Skill: surveillance_audit | Categoría:edr_xdr | Timestamp: 2026-05-23T12:02:28.892853

Qué es:

Agente EDR/XDR detectado. Estos sistemas monitorizan comportamiento del sistema en tiempo real para detectar amenazas.

Qué NO implica:

No implica necesariamente lectura de contenido personal. Es seguridad corporativa estándar en empresas medianas y grandes.

Riesgo técnico:

Monitoriza procesos, red y comportamiento del sistema.

Riesgo jurídico:

Riesgo legal estimado: low-medium. Ver compliance engine para análisis LOPDGDD/RGPD.

#4 — Certificado raíz de inspección SSL/TLS detectado

ORANGE

Skill: surveillance_audit | Categoría:ssl_inspection | Timestamp: 2026-05-23T12:02:39.670475

Qué es:

Un certificado raíz de inspección SSL permite al proxy corporativo actuar como intermediario en conexiones HTTPS, descifrando el tráfico para inspeccionarlo.

Qué NO implica:

No demuestra que el tráfico se esté leyendo activamente, pero sí que existe la capacidad técnica.

Riesgo técnico:

Con este certificado instalado, un proxy corporativo puede descifrar, analizar y registrar todo el tráfico HTTPS, incluyendo contraseñas y contenido de páginas web.

Riesgo jurídico:

Requiere informar explícitamente al trabajador. Sin información previa puede vulnerar art. 87 LOPDGDD y doctrina Barbulescu II (TEDH).

#5 — Extensiones de navegador forzadas por política corporativa

ORANGE

Skill: surveillance_audit | Categoría:browser_inspection | Timestamp: 2026-05-23T12:02:39.734309

Qué es:

Extensiones instaladas por GPO/política que el usuario no puede desinstalar.

Qué NO implica:

No implica necesariamente espionaje. Muchas son extensiones de seguridad o DLP legítimas.

Riesgo técnico:

Las extensiones forzadas pueden tener acceso completo al contenido de páginas web, historial y formularios.

Riesgo jurídico:

Depende de la funcionalidad de cada extensión. Si capturan contenido web personal, aplica LOPDGDD art. 87.

#6 — Servicios con características de monitorización (25 detectados)

YELLOW

Skill: persistence_audit | Categoría: persistence_services | Timestamp: 2026-05-23T12:02:39.944205

Qué es:

Servicios de Windows que se ejecutan continuamente en segundo plano.

Qué NO implica:

No todo servicio con estas palabras es espionaje. Windows incluye muchos servicios de telemetría propios.

Riesgo técnico:

Los servicios de Windows se ejecutan en segundo plano con privilegios elevados y pueden monitorizar el sistema.

Riesgo jurídico:

Depende de la funcionalidad real. Requiere análisis individual de cada servicio.

#7 — Conexiones externas activas (19 establecidas)

YELLOW

Skill: network_monitor | Categoría: network_external | Timestamp: 2026-05-23T12:03:40.505237

Qué es:

Conexiones TCP activas desde este equipo hacia servidores en Internet.

Qué NO implica:

No implica exfiltración de datos personales. La mayoría son actualizaciones, telemetría de SO y aplicaciones legítimas.

Riesgo técnico:

Las conexiones externas establecidas pueden corresponder a agentes corporativos enviando telemetría, datos de monitorización o actualizaciones.

Riesgo jurídico:

Las conexiones en sí no implican ilegalidad. El riesgo depende del tipo de datos transmitidos.

#8 — Procesos con alto consumo de recursos (17 detectados)

YELLOW

Skill: activity_monitor | Categoría: activity_resources | Timestamp: 2026-05-23T12:04:57.109336

Qué es:

Procesos que consumen más recursos de lo normal, lo que puede indicar actividad de análisis en segundo plano.

Qué NO implica:

Puede ser actividad legítima: compilaciones, antivirus escaneando, actualizaciones, backups.

Riesgo técnico:

Los procesos con alto consumo pueden estar procesando o transmitiendo grandes volúmenes de datos del sistema.

Riesgo jurídico:

Por sí solo no implica ilegalidad. Requiere identificación del proceso.

#9 — Servicios instalados en los últimos 7 días (5)

YELLOW

Skill: activity_monitor | Categoría: activity_new_services | Timestamp: 2026-05-23T12:06:25.548117

Qué es:

Registro de servicios de Windows instalados en la última semana.

Qué NO implica:

Puede ser actualizaciones de Windows, software corporativo estándar o drivers.

Riesgo técnico:

Los servicios nuevos pueden incluir agentes de monitorización instalados recientemente.

Riesgo jurídico:

Documentar servicios instalados recientemente es relevante para establecer el momento de implantación de herramientas de vigilancia.

#10 — Procesos con múltiples conexiones salientes (2)

YELLOW

Skill: activity_monitor | Categoría: activity_data_senders | Timestamp: 2026-05-23T12:06:33.177596

Qué es:

Procesos que mantienen varias conexiones de red abiertas simultáneamente.

Qué NO implica:

Navegadores y aplicaciones modernas mantienen múltiples conexiones por diseño.

Riesgo técnico:

Múltiples conexiones simultáneas pueden indicar envío de datos a varios servidores en paralelo.

Riesgo jurídico:

Requiere identificación de los procesos y sus destinos para evaluar el riesgo real.

#11 — Posible acceso al portapapeles detectado (1 apps)

ORANGE

Skill: privacy_audit | Categoría: privacy_clipboard | Timestamp: 2026-05-23T12:06:33.274646

Qué es:

Software con acceso al portapapeles del sistema, que puede leer lo que el usuario copia.

Qué NO implica:

Gestores de portapapeles como Ditto o ClipX son herramientas legítimas de productividad.

Riesgo técnico:

El portapapeles puede contener contraseñas, tokens, datos bancarios y comunicaciones privadas copiadas recientemente.

Riesgo jurídico:

El acceso al portapapeles sin consentimiento puede capturar datos especialmente sensibles. Alto riesgo bajo RGPD art. 9 si incluye datos de categoría especial.

#12 — Nivel de telemetría de Windows: Completa (por defecto, sin política restrictiva)

RED

Skill: ai_telemetry_audit | Categoría: telemetry_windows_level | Timestamp: 2026-05-23T12:06:43.502025

Qué es:

Windows envía datos de uso, diagnóstico y en niveles altos contenido de documentos y actividad del usuario a servidores de Microsoft en EEUU.

Qué NO implica:

No todo dato enviado es ilegal. La base legal puede ser interés legítimo o contrato de servicio. El problema es la falta de transparencia y control.

Riesgo técnico:

Nivel Completo (3): Microsoft recopila contenido de documentos, historial de navegación, uso de aplicaciones, búsquedas, voz, tinta digital y diagnósticos detallados del sistema. Nivel Básico (1): hardware, crashes, compatibilidad. Nivel Mejorado (2): uso de apps y rendimiento.

Riesgo jurídico:

La telemetría de nivel completo transfiere datos personales a Microsoft fuera del EEE sin control explícito del trabajador. Requiere análisis bajo RGPD capítulo V (transferencias internacionales) y base legal bajo art. 6 RGPD.

#13 — Servicios de telemetría activos (3 en ejecución)

RED

Skill: ai_telemetry_audit | Categoría: telemetry_services | Timestamp: 2026-05-23T12:07:25.330222

Qué es:

Servicios de Windows que recopilan y transmiten datos de uso, errores y diagnóstico a Microsoft.

Qué NO implica:

No todos los datos son personales en sentido estricto. Muchos son datos técnicos de hardware y estabilidad.

Riesgo técnico:

DiagTrack (Connected User Experiences) es el servicio principal de telemetría. Recopila continuamente datos de actividad y los envía a Microsoft. No se puede desactivar completamente en Windows 11 Home.

Riesgo jurídico:

Los servicios de telemetría operan como tratamiento continuo de datos personales. En equipos corporativos el empleador es corresponsable del tratamiento bajo RGPD art. 26.

#14 — Telemetría de Microsoft Office/365

ORANGE

Skill: ai_telemetry_audit | Categoría: telemetry_office | Timestamp: 2026-05-23T12:07:28.396842

Qué es:

Sistema de telemetría de Microsoft Office que recopila datos de uso y en algunos casos contenido de documentos.

Qué NO implica:

Microsoft afirma que el contenido de documentos no se usa sin consentimiento. Los Terms of Service tienen excepciones amplias.

Riesgo técnico:

Office 365 puede enviar: nombres de archivos, tipos de contenido, funciones usadas, errores, y con servicios conectados activos: fragmentos de texto para traducción, corrección y sugerencias de IA.

Riesgo jurídico:

El envío de contenido de documentos laborales a Microsoft puede incluir datos personales de terceros (clientes, empleados) sin base legal adecuada. Responsabilidad del empleador como responsable del tratamiento.

#15 — Experiencias conectadas de Office activas — contenido enviado a Microsoft

ORANGE

Skill: ai_telemetry_audit | Categoría: ai_connected_experiences | Timestamp: 2026-05-23T12:07:38.714166

Qué es:

Funciones de Microsoft 365 que requieren enviar contenido a servidores de Microsoft para funcionar: traducción, diseño, sugerencias de IA.

Qué NO implica:

No es espionaje directo. Es el modelo de negocio de SaaS: el servicio requiere acceso al contenido para funcionar. El problema es la transparencia y el control del usuario.

Riesgo técnico:

Las experiencias conectadas incluyen: traducción automática de documentos, sugerencias de escritura con IA (Editor), búsqueda inteligente (contenido enviado a Bing), PowerPoint Designer (imágenes y contenido de diapositivas), y análisis de datos en Excel con IA.

Riesgo jurídico:

El contenido de documentos laborales que se envía a Microsoft para procesamiento de IA puede incluir datos personales de clientes o empleados. El empleador debe tener DPA con Microsoft y base legal bajo RGPD art. 6 y 28.

#16 — Microsoft OneDrive activo — sincronización en segundo plano

ORANGE

Skill: cloud_sync_audit | Categoría: cloud_sync_service | Timestamp: 2026-05-23T12:07:38.923894

Qué es:

Microsoft OneDrive sincroniza automáticamente archivos locales hacia servidores en la nube, manteniéndolos accesibles desde cualquier dispositivo.

Qué NO implica:

La sincronización en nube no implica acceso no autorizado por terceros. El riesgo es la transferencia de datos sin control explícito y la accesibilidad desde otros dispositivos.

Riesgo técnico:

Datos sincronizados: Archivos del perfil de usuario, documentos, escritorio. Destino: Microsoft Azure (EEUU/UE según configuración). La sincronización ocurre automáticamente en segundo plano sin intervención del usuario.

Riesgo jurídico:

La sincronización automática puede constituir transferencia internacional de datos personales bajo RGPD cap. V. En equipos corporativos el empleador debe tener DPA con el proveedor de nube y base legal adecuada.

#17 — SharePoint / OneDrive Empresarial activo — sincronización en segundo plano

ORANGE

Skill: cloud_sync_audit | Categoría: cloud_sync_service | Timestamp: 2026-05-23T12:07:39.094265

Qué es:

SharePoint / OneDrive Empresarial sincroniza automáticamente archivos locales hacia servidores en la nube, manteniéndolos accesibles desde cualquier dispositivo.

Qué NO implica:

La sincronización en nube no implica acceso no autorizado por terceros. El riesgo es la transferencia de datos sin control explícito y la accesibilidad desde otros dispositivos.

Riesgo técnico:

Datos sincronizados: Documentos corporativos, librerías de SharePoint. Destino: Microsoft 365 (tenant corporativo). La sincronización ocurre automáticamente en segundo plano sin intervención del usuario.

Riesgo jurídico:

La sincronización automática puede constituir transferencia internacional de datos personales bajo RGPD cap. V. En equipos corporativos el empleador debe tener DPA con el proveedor de nube y base legal adecuada.

#18 — Carpetas del sistema redirigidas a nube (7 carpetas)

RED

Skill: cloud_sync_audit | Categoría: cloud_sync_folder_redirect | Timestamp: 2026-05-23T12:07:39.224073

Qué es:

Redirección de carpetas de Windows hacia OneDrive/SharePoint, convirtiendo el almacenamiento local en almacenamiento corporativo en la nube.

Qué NO implica:

Es una práctica común en entornos corporativos para backup y acceso multi-dispositivo. No implica lectura activa de contenidos, pero sí acceso técnico posible.

Riesgo técnico:

Cada archivo que el trabajador guarda en estas carpetas se sincroniza automáticamente a la nube sin ninguna acción adicional. Incluye: documentos de trabajo, archivos personales, screenshots, descargas guardadas en escritorio.

Riesgo jurídico:

La redirección automática de carpetas del sistema implica que el empleador (a través de Microsoft 365) tiene acceso inmediato a cualquier archivo guardado. Esto puede incluir notas personales, documentos sindicales o comunicaciones privadas. LOPDGDD art. 87 y ET art. 20bis requieren información previa y proporcionalidad.

#19 — Políticas corporativas de OneDrive activas — KFM forzado por GPO

ORANGE

Skill: cloud_sync_audit | Categoría: cloud_sync_policy | Timestamp: 2026-05-23T12:07:39.288795

Qué es:

Configuración GPO que controla cómo OneDrive se comporta en los equipos de la organización.

Qué NO implica:

Las políticas GPO de OneDrive son gestión IT corporativa legítima. El problema es la transparencia hacia el trabajador.

Riesgo técnico:

Las políticas GPO de OneDrive pueden forzar la sincronización de carpetas del sistema sin que el usuario pueda desactivarla. 'KFMBlockOptOut' impide que el trabajador desactive la sincronización de Escritorio y Documentos.

Riesgo jurídico:

Forzar KFM mediante GPO sin información previa al trabajador puede vulnerar LOPDGDD art. 87. El trabajador no puede controlar qué datos se sincronizan a la nube corporativa.

#20 — Extensiones forzadas por política corporativa (1 extensiones)

ORANGE

Skill: browser_audit | Categoría: browser_forced_extensions | Timestamp: 2026-05-23T12:07:39.348890

Qué es:

Extensiones de navegador instaladas por la empresa mediante política GPO que no pueden ser eliminadas por el usuario.

Qué NO implica:

No todas son espionaje. Muchas son herramientas de seguridad, SSO o DLP legítimas. El problema es la falta de transparencia sobre qué datos recopilan.

Riesgo técnico:

Las extensiones forzadas tienen acceso completo al navegador: contenido de páginas, formularios, contraseñas introducidas, historial y cookies. Algunas pueden interceptar o modificar el tráfico web.

Riesgo jurídico:

Las extensiones con permisos amplios instaladas sin conocimiento explícito del trabajador pueden vulnerar LOPDGDD art. 87. Requieren información previa sobre su función y datos que recopilan.

#21 — Políticas corporativas en Google Chrome (3 activas)

ORANGE

Skill: browser_audit | Categoría: browser_policies | Timestamp: 2026-05-23T12:07:39.490027

Qué es:

Políticas GPO que controlan el comportamiento del navegador: qué puede hacer el usuario, qué datos se envían y cómo se gestiona la sesión.

Qué NO implica:

Las políticas de navegador son gestión corporativa estándar. El problema es cuándo incluyen reporting de actividad sin transparencia.

Riesgo técnico:

CloudReportingEnabled envía datos de actividad del navegador al administrador corporativo. El bloqueo del modo incógnito impide al trabajador tener sesiones de navegación privadas. BrowserSignin forzado vincula la actividad al perfil corporativo y la sincroniza.

Riesgo jurídico:

CloudReportingEnabled sin información previa al trabajador puede vulnerar LOPDGDD art. 87. El bloqueo del modo incógnito elimina una herramienta de privacidad del trabajador.

#22 — Políticas corporativas en Microsoft Edge (4 activas)

ORANGE

Skill: browser_audit | Categoría: browser_policies | Timestamp: 2026-05-23T12:07:39.533851

Qué es:

Políticas GPO que controlan el comportamiento del navegador: qué puede hacer el usuario, qué datos se envían y cómo se gestiona la sesión.

Qué NO implica:

Las políticas de navegador son gestión corporativa estándar. El problema es cuándo incluyen reporting de actividad sin transparencia.

Riesgo técnico:

CloudReportingEnabled envía datos de actividad del navegador al administrador corporativo. El bloqueo del modo incógnito impide al trabajador tener sesiones de navegación privadas. BrowserSignin forzado vincula la actividad al perfil corporativo y la sincroniza.

Riesgo jurídico:

CloudReportingEnabled sin información previa al trabajador puede vulnerar LOPDGDD art. 87. El bloqueo del modo incógnito elimina una herramienta de privacidad del trabajador.

#23 — Políticas corporativas en Mozilla Firefox (1 activas)

ORANGE

Skill: browser_audit | Categoría: browser_policies | Timestamp: 2026-05-23T12:07:39.577212

Qué es:

Políticas GPO que controlan el comportamiento del navegador: qué puede hacer el usuario, qué datos se envían y cómo se gestiona la sesión.

Qué NO implica:

Las políticas de navegador son gestión corporativa estándar. El problema es cuándo incluyen reporting de actividad sin transparencia.

Riesgo técnico:

CloudReportingEnabled envía datos de actividad del navegador al administrador corporativo. El bloqueo del modo incógnito impide al trabajador tener sesiones de navegación privadas. BrowserSignin forzado vincula la actividad al perfil corporativo y la sincroniza.

Riesgo jurídico:

CloudReportingEnabled sin información previa al trabajador puede vulnerar LOPDGDD art. 87. El bloqueo del modo incógnito elimina una herramienta de privacidad del trabajador.

#24 — Configuraciones de seguridad ausentes (8 de 14)

RED

Skill: hardening_audit | Categoría: hardening_missing | Timestamp: 2026-05-23T12:08:56.412451

Qué es:

Configuraciones de seguridad de Windows que deberían estar activas en un equipo corporativo gestionado pero no lo están.

Qué NO implica:

No implica que el equipo esté comprometido. Indica que las protecciones estándar no se han aplicado, lo que aumenta la superficie de riesgo.

Riesgo técnico:

Las configuraciones de seguridad ausentes reducen la protección del sistema y pueden facilitar la instalación o ejecución de software no autorizado, incluyendo herramientas de vigilancia.

Riesgo jurídico:

El empleador tiene obligación de garantizar la seguridad de los equipos corporativos bajo RGPD art. 32. La ausencia de medidas técnicas básicas puede constituir incumplimiento de esta obligación.

#25 — AUSENTE: BitLocker — Cifrado de disco

RED

Skill: hardening_audit | Categoría: hardening_encryption | Timestamp: 2026-05-23T12:09:01.416705

Qué es:

BitLocker — Cifrado de disco

Qué NO implica:

No implica que haya ocurrido un incidente. Es una protección que debería estar activa y no lo está.

Riesgo técnico:

Los datos del disco son accesibles sin autenticación si se extrae el disco o se arranca desde medio externo.

Riesgo jurídico:

El empleador tiene obligación bajo RGPD art. 32 de implementar medidas técnicas apropiadas. La ausencia de esta medida puede ser relevante en caso de incidente de seguridad.

#26 — AUSENTE: Secure Boot — Arranque seguro

ORANGE

Skill: hardening_audit | Categoría: hardening_boot | Timestamp: 2026-05-23T12:09:01.443129

Qué es:

Secure Boot — Arranque seguro

Qué NO implica:

No implica que haya ocurrido un incidente. Es una protección que debería estar activa y no lo está.

Riesgo técnico:

El sistema puede ser comprometido a nivel de firmware sin que ninguna herramienta de seguridad lo detecte.

Riesgo jurídico:

El empleador tiene obligación bajo RGPD art. 32 de implementar medidas técnicas apropiadas. La ausencia de esta medida puede ser relevante en caso de incidente de seguridad.

#27 — AUSENTE: Windows Firewall — Cortafuegos

ORANGE

Skill: hardening_audit | Categoría: hardening_network | Timestamp: 2026-05-23T12:09:01.473678

Qué es:

Windows Firewall — Cortafuegos

Qué NO implica:

No implica que haya ocurrido un incidente. Es una protección que debería estar activa y no lo está.

Riesgo técnico:

El equipo está expuesto a conexiones entrantes desde la red local sin filtrado.

Riesgo jurídico:

El empleador tiene obligación bajo RGPD art. 32 de implementar medidas técnicas apropiadas. La ausencia de esta medida puede ser relevante en caso de incidente de seguridad.

#28 — AUSENTE: Windows Defender — Protección en tiempo real

ORANGE

Skill: hardening_audit | Categoría: hardening_antimalware | Timestamp: 2026-05-23T12:09:01.501521

Qué es:

Windows Defender — Protección en tiempo real

Qué NO implica:

No implica que haya ocurrido un incidente. Es una protección que debería estar activa y no lo está.

Riesgo técnico:

Malware puede ejecutarse libremente sin detección hasta el próximo análisis manual.

Riesgo jurídico:

El empleador tiene obligación bajo RGPD art. 32 de implementar medidas técnicas apropiadas. La ausencia de esta medida puede ser relevante en caso de incidente de seguridad.

#29 — Grupo Administradores: 4 miembros

ORANGE

Skill: identity_audit | Categoría: identity_admin_group | Timestamp: 2026-05-23T12:09:35.676702

Qué es:

Lista de cuentas con privilegios de administrador local en el equipo del trabajador.

Qué NO implica:

Tener administradores corporativos en el equipo es normal en entornos gestionados. El problema es la falta de transparencia sobre quién tiene acceso y con qué finalidad.

Riesgo técnico:

Los administradores locales tienen acceso completo al equipo: pueden leer cualquier archivo, instalar software, acceder a credenciales y monitorizar toda la actividad.

Riesgo jurídico:

El trabajador tiene derecho a saber qué cuentas tienen acceso administrativo a su equipo. Un número elevado de administradores aumenta el riesgo de acceso no autorizado. LOPDGDD art. 87 y RGPD art. 32.

#30 — Acceso remoto habilitado

ORANGE

Skill: identity_audit | Categoría: identity_remote_access | Timestamp: 2026-05-23T12:09:46.600719

Qué es:

Protocolo de escritorio remoto que permite a terceros ver y controlar el equipo a través de la red.

Qué NO implica:

RDP habilitado es normal en entornos corporativos para soporte técnico. El problema es el acceso sin notificación ni consentimiento del trabajador.

Riesgo técnico:

Con RDP habilitado, cualquier administrador puede conectarse remotamente al escritorio del trabajador y ver o controlar todo. Una conexión RDP activa significa que alguien puede estar viendo el escritorio ahora mismo.

Riesgo jurídico:

El acceso remoto al escritorio sin notificación al trabajador puede constituir vigilancia encubierta bajo LOPDGDD art. 87. Una conexión RDP activa no consentida podría vulnerar adicionalmente el art. 197 del Código Penal.

#31 — Credenciales almacenadas en Windows Credential Manager (42)

ORANGE

Skill: identity_audit | Categoría: identity_stored_credentials | Timestamp: 2026-05-23T12:09:46.928592

Qué es:

Almacén seguro de Windows donde se guardan credenciales para acceso automático a recursos de red, RDP y otros servicios.

Qué NO implica:

No es un keylogger. Son credenciales que el usuario guardó voluntariamente para no introducirlas cada vez.

Riesgo técnico:

Las credenciales almacenadas en Windows Credential Manager están cifradas con la clave del perfil de usuario. Un proceso con privilegios de administrador puede extraerlas usando herramientas estándar.

Riesgo jurídico:

Las credenciales almacenadas pueden incluir contraseñas de sistemas personales del trabajador. Su acceso no autorizado vulnera LOPDGDD y puede constituir delito bajo CP art. 197.

#32 — Servicios con cuentas de usuario específicas (8)

YELLOW

Skill: identity_audit | Categoría: identity_service_accounts | Timestamp: 2026-05-23T12:09:47.337606

Qué es:

Servicios de Windows que utilizan cuentas de usuario con credenciales específicas en lugar de las cuentas de sistema estándar.

Qué NO implica:

Es una práctica común en entornos corporativos para servicios que necesitan acceso a recursos de red. No implica actividad maliciosa.

Riesgo técnico:

Servicios que corren bajo cuentas de usuario específicas tienen acceso a los recursos de esa cuenta: archivos, red, credenciales. Si la cuenta tiene privilegios elevados, el servicio también.

Riesgo jurídico:

Servicios de monitorización que corren bajo cuentas de dominio pueden acceder a recursos corporativos con privilegios del usuario. Relevante para determinar el alcance real de la vigilancia.

#33 — Procesos de monitorización con privilegios de sistema (1)

YELLOW

Skill: identity_audit | Categoría: identity_privileged_monitoring | Timestamp: 2026-05-23T12:10:07.194472

Qué es:

Servicios de seguridad que operan con la cuenta SYSTEM de Windows, necesaria para proteger el sistema a nivel de kernel.

Qué NO implica:

Es normal que los agentes EDR/AV corran como SYSTEM. Es un requisito técnico para su función de seguridad, no indica uso indebido.

Riesgo técnico:

Los procesos de SISTEMA tienen acceso sin restricciones a todos los archivos, memoria, red y configuración del equipo. Es el contexto de mayor privilegio posible.

Riesgo jurídico:

Agentes corporativos con privilegios de SISTEMA tienen capacidad técnica para acceder a cualquier dato del trabajador. Su alcance real depende de su configuración, no de sus privilegios técnicos.

#34 — Perfiles de cuentas — 5 con alertas (3 alto riesgo)

ORANGE

Skill: identity_audit | Categoría: identity_account_profiles | Timestamp: 2026-05-23T12:14:20.128599

Qué es:

Análisis de cada cuenta de usuario del sistema: qué es, qué hace, cuándo fue usada por última vez y por qué puede ser relevante.

Qué NO implica:

No todas las cuentas con alertas son maliciosas. Muchas son cuentas de servicio legítimas. El perfil ayuda a identificar cuáles merecen justificación documentada.

Riesgo técnico:

Cuentas con privilegios elevados, contraseña permanente o nunca usadas pueden ser vectores de acceso no autorizado al equipo.

Riesgo jurídico:

El trabajador tiene derecho a conocer qué cuentas tienen acceso a su dispositivo y con qué finalidad. LOPDGDD art. 87 y RGPD art. 32.

#35 — Cuenta: DevToolsUser — 2 alertas

ORANGE

Skill: identity_audit | Categoría: identity_suspicious_account | Timestamp: 2026-05-23T12:14:20.152104

Qué es:

Cuenta 'DevToolsUser' detectada con: grupos=['Usuarios de escritorio remoto'], servicios=0, último acceso=Nunca.

Qué NO implica:

Puede ser una cuenta de servicio corporativo legítima. La alerta indica que merece justificación documentada por parte del empleador.

Riesgo técnico:

■■ En grupos de alto privilegio: usuarios de escritorio remoto ■■ Cuenta local habilitada — no es cuenta de dominio

Riesgo jurídico:

Esta cuenta puede tener acceso al equipo del trabajador. Su presencia sin documentación puede vulnerar LOPDGDD art. 87.

#36 — Cuenta: EMEAL-IT — 2 alertas

RED

Skill: identity_audit | Categoría: identity_suspicious_account | Timestamp: 2026-05-23T12:14:20.174379

Qué es:

Cuenta 'EMEAL-IT' detectada con: grupos=['USERS', 'Administradores', 'IIS_IUSRS', 'Usuarios de escritorio remoto', 'Usuarios del registro de rendimiento'], servicios=0, último acceso=/Date(1723032530209)/.

Qué NO implica:

Puede ser una cuenta de servicio corporativo legítima. La alerta indica que merece justificación documentada por parte del empleador.

Riesgo técnico:

■■ En grupos de alto privilegio: administradores, usuarios de escritorio remoto ■■ Cuenta local habilitada — no es cuenta de dominio

Riesgo jurídico:

Esta cuenta puede tener acceso al equipo del trabajador. Su presencia sin documentación puede vulnerar LOPDGDD art. 87.

#37 — Cuenta: Local-Admin — 3 alertas

RED

Skill: identity_audit | Categoría: identity_suspicious_account | Timestamp: 2026-05-23T12:14:20.201353

Qué es:

Cuenta 'Local-Admin' detectada con: grupos=['Administradores', 'Usuarios de escritorio remoto'], servicios=0, último acceso=/Date(1779366426728)/.

Qué NO implica:

Puede ser una cuenta de servicio corporativo legítima. La alerta indica que merece justificación documentada por parte del empleador.

Riesgo técnico:

■■ En grupos de alto privilegio: administradores, usuarios de escritorio remoto ■■ Nombre sugiere función especial: admin ■■ Cuenta local habilitada — no es cuenta de dominio

Riesgo jurídico:

Esta cuenta puede tener acceso al equipo del trabajador. Su presencia sin documentación puede vulnerar LOPDGDD art. 87.

Evaluación Legal

Telemetría completa de Windows activa

HIGH

Windows en nivel de telemetría completo envía datos de actividad, contenido de documentos y uso de aplicaciones a Microsoft en EEUU. Transferencia internacional sin control explícito del trabajador. El empleador como responsable del tratamiento debe garantizar una base legal adecuada bajo RGPD cap. V.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.

Recomendaciones:

- Solicitar al DPO la base legal de la telemetría de Windows.
 - Verificar si existe DPA entre la empresa y Microsoft.
 - Solicitar que IT aplique política GPO de telemetría mínima.
 - Exigir registro de actividades de tratamiento que incluya esta transferencia.
-

Servicio DiagTrack — telemetría continua activa

HIGH

DiagTrack recopila y envía datos de actividad continuamente. En equipos corporativos el empleador es corresponsable del tratamiento bajo RGPD art. 26. No haberlo desactivado por política es una omisión relevante.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.

Recomendaciones:

- Solicitar a IT que deshabilite DiagTrack via GPO.
 - Verificar que la empresa tiene DPA vigente con Microsoft.
 - Documentar el estado actual como evidencia.
 - Solicitar el registro de actividades de tratamiento.
-

Carpetas del sistema redirigidas a nube corporativa

HIGH

Las carpetas principales de Windows apuntan a OneDrive/SharePoint. Todo lo guardado es inmediatamente accesible por el empleador a través de Microsoft 365.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **ET Art. 20 bis — Derechos de los trabajadores a la intimidad:** Los trabajadores tienen derecho a la intimidad en el uso de dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente a la geolocalización.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.

Recomendaciones:

- Documentar qué carpetas están redirigidas.
- Solicitar política de acceso a datos del empleador.
- Crear carpetas locales fuera de OneDrive para uso personal.
- Consultar con asesor laboral sobre el alcance del acceso.

Cifrado de disco no activo — datos en claro

HIGH

Sin BitLocker activo, en caso de pérdida o robo del equipo todos los datos del trabajador son accesibles sin autenticación. El empleador incumple RGPD art. 32 al no aplicar cifrado en equipos corporativos.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Solicitar a IT la activación inmediata de BitLocker.
 - Documentar la ausencia como riesgo de seguridad.
 - Notificar al DPO como posible brecha de seguridad latente.
-

Acceso remoto habilitado al equipo del trabajador

HIGH

RDP habilitado permite acceso completo al escritorio sin que el trabajador lo sepa. Una conexión activa sin notificación puede constituir vigilancia encubierta y vulnerar CP art. 197.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **ET Art. 20 bis — Derechos de los trabajadores a la intimidad:** Los trabajadores tienen derecho a la intimidad en el uso de dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente a la geolocalización.
- **TEDH — Doctrina Barbulescu II (2017):** El Tribunal Europeo de Derechos Humanos estableció que la monitorización de comunicaciones laborales debe ser proporcional, limitada en alcance, con base legal, finalidad legítima e informada previamente al trabajador.

Recomendaciones:

- Solicitar al empleador política de acceso remoto documentada.
- Exigir notificación previa antes de cualquier acceso remoto.
- Verificar si existe registro de accesos remotos realizados.
- Consultar con asesor laboral si hay accesos no comunicados.

Inspección de tráfico HTTPS sin información acreditada

MEDIUM-HIGH

La inspección SSL permite al empleador leer contenido de comunicaciones cifradas. La doctrina Barbulescu II exige informar previamente al trabajador del alcance.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **TEDH — Doctrina Barbulescu II (2017):** El Tribunal Europeo de Derechos Humanos estableció que la monitorización de comunicaciones laborales debe ser proporcional, limitada en alcance, con base legal, finalidad legítima e informada previamente al trabajador.

Recomendaciones:

- Verificar si la empresa ha informado por escrito sobre la inspección de tráfico.
 - Evitar uso de cuentas personales en dispositivos corporativos.
 - Solicitar la política de uso aceptable (AUP) de la empresa.
-

Acceso al portapapeles del trabajador

MEDIUM-HIGH

El portapapeles puede contener contraseñas, tokens y datos bancarios. Su acceso por software corporativo sin consentimiento puede capturar datos especialmente sensibles bajo RGPD art. 9.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **ET Art. 20 bis — Derechos de los trabajadores a la intimidad:** Los trabajadores tienen derecho a la intimidad en el uso de dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente a la geolocalización.

Recomendaciones:

- Identificar qué aplicación accede al portapapeles.
- No copiar credenciales ni datos sensibles en equipos corporativos.
- Solicitar al DPO información sobre el tratamiento de estos datos.

Experiencias conectadas de Office enviando contenido a Microsoft

MEDIUM-HIGH

Office 365 envía contenido de documentos a Microsoft para funciones de IA: traducción, diseño, sugerencias. Puede incluir datos personales de clientes y empleados sin base legal adecuada o sin conocimiento del trabajador.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.

Recomendaciones:

- Solicitar el DPA entre la empresa y Microsoft.
- Verificar qué experiencias conectadas están activas.
- Solicitar DPIA si se procesan datos de categoría especial.
- Desactivar experiencias conectadas no necesarias para el trabajo.

Políticas GPO de OneDrive forzando sincronización

MEDIUM-HIGH

KFMBlockOptOut impide que el trabajador desactive la sincronización de sus carpetas principales. El trabajador no puede controlar qué datos van a la nube corporativa.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **ET Art. 20 bis — Derechos de los trabajadores a la intimidad:** Los trabajadores tienen derecho a la intimidad en el uso de dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente a la geolocalización.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.

Recomendaciones:

- Solicitar al empleador información sobre las políticas GPO.
- Verificar qué datos son accesibles por el admin de M365.
- Documentar la imposibilidad de desactivar la sincronización.

Extensiones forzadas con acceso completo al navegador

MEDIUM-HIGH

Extensiones GPO con permisos amplios pueden interceptar formularios, contraseñas y contenido web. Requieren información previa al trabajador sobre qué datos recopilan.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Solicitar al empleador listado de extensiones forzadas y su función.
- Verificar los permisos de cada extensión en `chrome://extensions`.
- No introducir datos personales en formularios web en equipos corporativos.

Configuraciones de seguridad básicas ausentes

MEDIUM-HIGH

El empleador tiene obligación bajo RGPD art. 32 de implementar medidas técnicas apropiadas. La ausencia de protecciones básicas puede constituir incumplimiento y aumenta el riesgo para los datos del trabajador.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Solicitar al empleador el plan de hardening de equipos.
- Exigir activación de BitLocker si no está presente.
- Documentar las ausencias como parte del informe forense.
- Presentar al DPO como posible incumplimiento RGPD art. 32.

Credenciales almacenadas accesibles para administradores

MEDIUM-HIGH

Las credenciales en Windows Credential Manager pueden ser extraídas por administradores. Si incluyen contraseñas personales del trabajador, su acceso no autorizado vulnera LOPDGDD y CP art. 197.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.

Recomendaciones:

- No guardar contraseñas personales en Windows Credential Manager.
- Usar un gestor de contraseñas personal independiente.
- Revisar qué credenciales están almacenadas con `cmdkey /list`.

Cuenta específica con características de riesgo

MEDIUM-HIGH

Una cuenta habilitada con privilegios elevados y sin uso documentado puede ser una puerta trasera para acceso no autorizado al equipo del trabajador.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 32 — Seguridad del tratamiento:** El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.
- **ET Art. 20 bis — Derechos de los trabajadores a la intimidad:** Los trabajadores tienen derecho a la intimidad en el uso de dispositivos digitales puestos a su disposición por el empleador, a la desconexión digital y a la intimidad frente a la geolocalización.

Recomendaciones:

- Solicitar justificación específica de esta cuenta al empleador.
- Verificar si aparece en el inventario oficial de cuentas.
- Consultar con asesor laboral si no hay justificación.
- Preservar este informe como evidencia.

Extensiones de navegador forzadas con acceso a contenido web

MEDIUM

Las extensiones corporativas con acceso completo a páginas web pueden leer formularios, contraseñas y contenido personal.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Identificar qué extensiones están instaladas y su editor.
- Solicitar información sobre su función a IT.
- No usar el navegador corporativo para asuntos personales.

Telemetría de Microsoft Office sin política restrictiva

MEDIUM

Office 365 recopila datos de uso, nombres de archivos y en configuración por defecto fragmentos de contenido. Sin política GPO restrictiva aplica la configuración más permisiva por defecto.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Solicitar a IT política GPO de privacidad de Office.
- Verificar el nivel de telemetría configurado.
- Comprobar que el DPA con Microsoft está actualizado.

Servicio de sincronización en nube activo

MEDIUM

La sincronización automática puede constituir transferencia internacional de datos personales bajo RGPD cap. V. El empleador debe tener DPA con el proveedor y base legal adecuada.

Referencias legales:

- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.
- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.

Recomendaciones:

- Solicitar al DPO el DPA con cada proveedor de nube activo.
- Verificar qué datos se sincronizan y hacia qué región.
- Solicitar el registro de actividades de tratamiento.

Políticas corporativas de navegador activas

MEDIUM

CloudReportingEnabled envía actividad del navegador al administrador. El bloqueo del modo incógnito elimina una herramienta de privacidad del trabajador.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 13 — Información al interesado:** El responsable debe informar al trabajador de qué datos se tratan, con qué finalidad, base legal y período de conservación, antes de iniciar el tratamiento.

Recomendaciones:

- Verificar si CloudReporting está activo en chrome://policy.
- Solicitar al DPO qué datos de navegación se recopilan.
- No usar el navegador corporativo para asuntos personales.

Múltiples administradores con acceso completo al equipo

MEDIUM

Un número elevado de administradores locales aumenta el riesgo de acceso no autorizado. El trabajador tiene derecho a saber quién puede acceder a su equipo y con qué finalidad.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 32 — Seguridad del tratamiento:** El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Recomendaciones:

- Solicitar al empleador lista de cuentas con acceso admin.
- Verificar que el número de admins está justificado.
- Exigir registro de auditoría de accesos administrativos.

Cuentas con alertas de seguridad sin documentar

MEDIUM

Cuentas habilitadas con privilegios elevados o nunca usadas pueden ser vectores de acceso no autorizado. El trabajador tiene derecho a saber qué cuentas tienen acceso a su dispositivo.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 32 — Seguridad del tratamiento:** El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Recomendaciones:

- Solicitar inventario completo de cuentas y su justificación.
- Exigir que IT deshabilite cuentas no necesarias.
- Documentar este informe como evidencia del estado actual.

Servicios con cuentas de usuario específicas

MEDIUM

Servicios que corren bajo cuentas de dominio tienen acceso a recursos de red con privilegios de esa cuenta. Si son cuentas de monitorización, su alcance real puede ser mayor del esperado.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 32 — Seguridad del tratamiento:** El responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Recomendaciones:

- Solicitar inventario de servicios y cuentas asociadas.
- Verificar que cada servicio tiene justificación documentada.
- Consultar al DPO si algún servicio trata datos del trabajador.

Agentes de monitorización con privilegios de SISTEMA

MEDIUM

Procesos de SISTEMA tienen acceso sin restricciones a todos los datos del equipo. Los agentes EDR con estos privilegios tienen capacidad técnica de acceso total.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.

Recomendaciones:

- Solicitar al DPO qué datos recopilan estos agentes.
- Verificar que existe política de uso de datos del EDR.
- Documentar qué agentes corren como SISTEMA.

Agente EDR/XDR corporativo

LOW

Los EDR son considerados seguridad corporativa estándar y generalmente cumplen el principio de proporcionalidad si están orientados a la detección de amenazas.

Referencias legales:

- **LOPDGDD Art. 87 — Derecho a la intimidad en el trabajo:** Los trabajadores tienen derecho a la intimidad frente al uso de dispositivos digitales. El empleador debe establecer criterios de uso e informar a los trabajadores y sus representantes.
- **RGPD Art. 5 — Principios del tratamiento:** Los datos personales deben tratarse de forma lícita, leal y transparente. Limitación de finalidad, minimización, exactitud, limitación del plazo de conservación e integridad.

Recomendaciones:

- Verificar que existe política de seguridad documentada.
- Comprobar que el uso de datos del EDR se limita a finalidades de seguridad.

Integridad del Informe

Este informe incluye un hash SHA-256 de su contenido para verificar que no ha sido modificado desde su generación.

SHA-256 del contenido:

fc064df20d6fc1372bcac8f2f947d0ee1ebd6447ceffd612cedde4f32af8015d

Para verificar la integridad, recalculé el hash del archivo JSON exportado junto a este informe y compárelo con el valor anterior.